מסמך ייזום: AI Incident Ledger

מה הפרויקט עושה

פלטפורמת דיווח מרכזית ("ledger" בלתי-ניתן-לשינוי) שאליה חברות AI מדווחות אירועי בטיחות (jailbreaks מוצלחים, נזק בפועל, כשלי alignment) בזמן אמת, במקום מנגנון מפוצל של חוקי דיווח שונים בכל מדינה.

מוטיבציה

הכתבה מדגימה איך אפילו חוק קליפורניה — הנחשב לפורץ דרך — לא כיסה את מקרה Hugging Face כי הוא קרה ב"שלב הערכה" (פסקה 6). המטרה: תשתית טכנית אחידה שלא תלויה בניסוח משפטי מדויק של אף מדינה בודדת.

קהל יעד

רגולטורים ברמת המדינה והפדרלית, עיתונאי טכנולוגיה, חוקרי AI safety, ובאופן עקיף — הציבור הרחב דרך דשבורד פומבי.

מטרות מרכזיות

- יצירת "מקור אמת" יחיד לאירועי בטיחות AI, בלתי תלוי בהגדרות משפטיות מקומיות.
- הפחתת זמן התגובה הרגולטורית.
- מתן תמריץ מוניטין לחברות "טובות" שמדווחות יותר.

פתרונות דומים קיימים

- CVE (Common Vulnerabilities and Exposures) — מאגר גלובלי מבוסס-MITRE לדיווח פרצות אבטחה בתוכנה. עובד היטב כי יש לו תמריץ ברור: חברות רוצות CVE כדי להראות שהן טיפלו בבעיה. הבעיה: ל-AI incidents אין את אותו תמריץ — הודאה בכשל AI פוגעת יותר במוניטין מהודאה בבאג רגיל.
- HackerOne / Bug Bounty Platforms — מנגנון תמריצים כספיים לחשיפת פרצות. מודל מעניין (תשלום תמורת שקיפות), אך לא נבחן מעולם על "כשלי alignment" שהם מושג עמום יותר מפרצת אבטחה קונקרטית.
- NIST AI Risk Management Framework — מסגרת אמריקאית וולונטרית לניהול סיכוני AI. מסגרת ניהולית (checklist), לא תשתית טכנית אכיפה.
- EU AI Act — כולל סעיפי דיווח incident לחברות "high-risk AI" — ברמת חוק, לא תשתית טכנית חוצת-גבולות.

אתגרים ומכשולים צפויים

- בעיית התמריץ (הקריטית ביותר): בניגוד ל-CVE, אין כאן win-win — לחברה אין תועלת ישירה מדיווח על עצמה.
- הגדרת "אירוע": טווח עצום בין "המודל ענה משהו לא נעים" לבין "המודל גרם נזק ממשי" — בלי קו גבול ברור, הדיווח הופך לשרירותי.

- אימות אמינות דיווח: איך יודעים שחברה לא מדווחת רק אירועים קלים כדי "להיראות שקופה" בעוד היא מסתירה אירועים חמורים?
- עומס משפטי סמוי: דיווח פומבי עלול לחשוף את החברה לתביעות — תמריץ שלילי נוסף שמחריף את בעיית התמריץ (1).

נפילה

נפל בשיא שלב הייזום — לא מחוסר ערך, אלא כי מימוש אמיתי דורש שהתעשייה כולה תאמץ את הפרוטוקול מרצון או בכפייה חוקית, החלטה שאינה בשליטת צוות פיתוח יחיד, ומכאן שזהו בבסיסו פרויקט מדיניות ולא מוצר הנדסי שניתן להדגים באמת לבד. בעיית התמריץ (אתגר 1) היא זו שחתמה את גורלו: בניגוד ל-CVE, לחברה אין שום תועלת ישירה מהודאה בכשל בטיחות משלה. הרעיון הטכני המרכזי שלו — יומן Merkle פומבי עם Signed Tree Heads — לא הלך לאיבוד: הוא חי מחדש בתוך Model Kill-Switch Protocol כפיצ'ר "יומן שקיפות" (Certificate Transparency) ממוקד בהרבה, שמתעד רק פקודות ניהול על מודל בודד — ובתוך Coordinated Pause Escrow System כיומן ה-commitments הפומבי.